

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО
ITMO University

ПРАКТИЧЕСКАЯ РАБОТА 2

По дисциплине Администрирование платформ на ОС Linux

Тема работы Nginx

Обучающийся Пухарев Сергей Валерьевич

Факультет факультет прикладной информатики

Группа K3220

Направление подготовки 11.03.02 Инфокоммуникационные технологии и
системы связи

Образовательная программа Программирование в инфокоммуникационных
системах

Обучающийся	_____	_____	<u>Пухарев С.В.</u>
	(дата)	(подпись)	(Ф.И.О.)
Руководитель	_____	_____	<u>Береснев А.Д.</u>
	(дата)	(подпись)	(Ф.И.О.)

СОДЕРЖАНИЕ

ВВЕДЕНИЕ.....	3
1 ПОДГОТОВКА.....	4
2 НАПИСАНИЕ КОНФИГУРАЦИИ.....	4
3 DOS АТАКА	6
4 ОТВЕТЫ НА ВОПРОСЫ.....	7
ЗАКЛЮЧЕНИЕ	9

ВВЕДЕНИЕ

Цель работы – развернуть Nginx для веб-приложения и применить бестпрактис в конфигурации.

1 ПОДГОТОВКА

В самом начале были установлены необходимые модули и созданы директории (рисунок 1).

```
All packages are up to date.
root@pukharevsv:~# sudo apt update
sudo apt install -y nginx nodejs npm git nload
sudo mkdir -p /opt/librespeed
sudo chown $USER:$USER /opt/librespeed
cd /opt/librespeed
git clone -b node https://github.com/librespeed/speedtest.git
cd speedtest/src
npm install
Hit:1 https://mirrors.ubuntu.com/mirrors.txt InRelease
```

Рисунок 1 – Подготовка

Далее в файле SpeedTest.js был изменён код (рисунок 2):

```
const PORT = process.argv[2] || 8888;
Server.listen(PORT, '127.0.0.1', function () {
  console.log(`Speedtest Server is up and running on ${PORT}!`);
});

Server.get('/whoami', function (req, res) {
  res.json({
    port: PORT,
    pid: process.pid
  });
});
```

Рисунок 2 – SpeedTest.js

2 НАПИСАНИЕ КОНФИГУРАЦИИ

Далее в соответствии с требованиями был написано nginx-конфиг для librespeed, а также установлен сертификат Let's Encrypt, который сам внёс некоторые изменения в файл конфига. Итоговый файл представлен на рисунке 3.

```

upstream libspeed_backend {
    server 127.0.0.1:8888;
    server 127.0.0.1:8889;
    server 127.0.0.1:8890;
}

client_body_buffer_size 1k;
client_header_buffer_size 1k;
client_max_body_size 1k;
large_client_header_buffers 2 1k;

server {
    listen 80;
    server_name seraypuh.duckdns.org;
    return 301 https://$server_name$request_uri;
}

server {
    listen 80;
    listen 443 ssl;
    server_name "";
    ssl_certificate /etc/letsencrypt/live/seraypuh.duckdns.org/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/seraypuh.duckdns.org/privkey.pem;
    return 444;
}

server {
    listen 443 ssl http2;
    server_name seraypuh.duckdns.org;

    ssl_certificate /etc/letsencrypt/live/seraypuh.duckdns.org/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/seraypuh.duckdns.org/privkey.pem;

    root /opt/librespeed/speedtest/src/public;

    server_tokens off;

    if ($request_method !~ ^(GET|POST)$) {
        return 405;
    }

    if ($http_user_agent ~* (msnbot|scrapbot|wget|curl|aria2)) {
        return 403;
    }

    add_header X-Frame-Options "SAMEORIGIN" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header X-XSS-Protection "1; mode=block" always;
    add_header Referrer-Policy "no-referrer-when-downgrade" always;
    add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;

    location / {
        proxy_pass http://libspeed_backend;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}

```

Рисунок 3 – librespeed.conf

Далее был проверен синтаксис файла и запущен сам сайт (рисунок 4, 5).

```
root@pukharevsv:~# sudo ln -s /etc/nginx/sites-available/librespeed.conf /etc/nginx/sites-enabled/  
sudo nginx -t  
sudo systemctl reload nginx  
ln: failed to create symbolic link '/etc/nginx/sites-enabled/librespeed.conf': File exists  
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok  
nginx: configuration file /etc/nginx/nginx.conf test is successful  
root@pukharevsv:~#
```

Рисунок 4 – Проверка файла

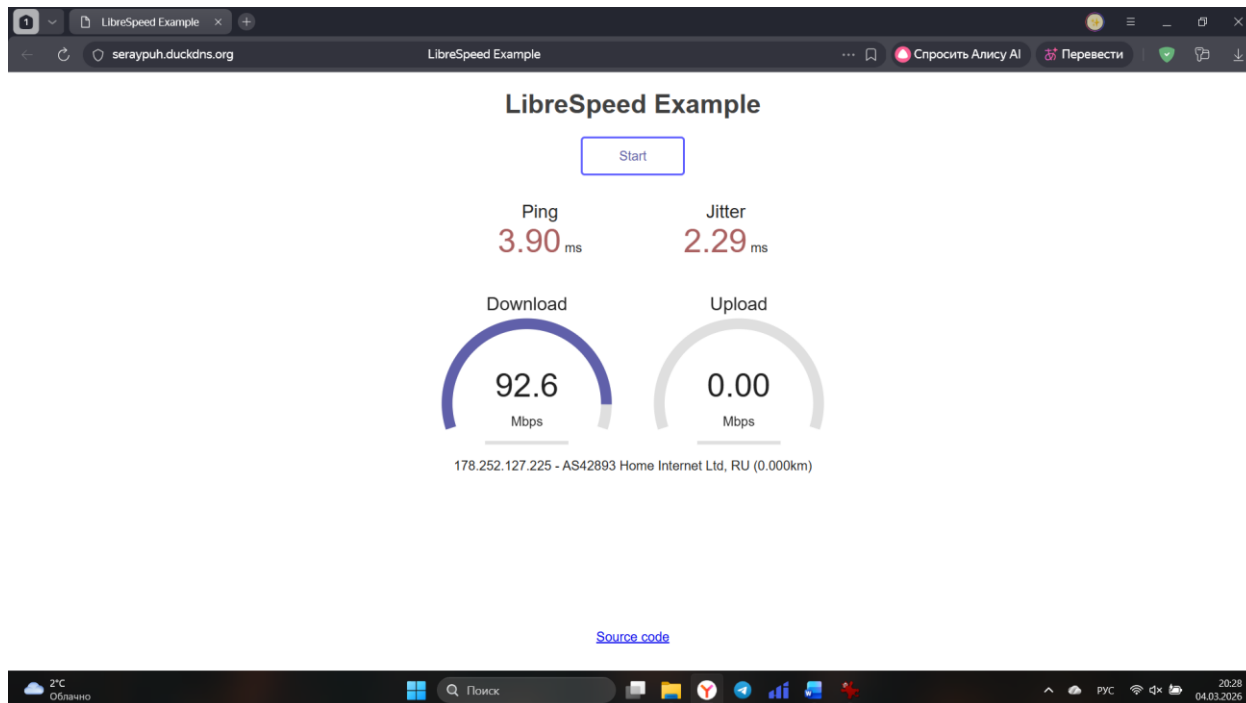


Рисунок 5 – Сайт

3 DOS АТАКА

Далее было необходимо создать Slowloris-атаку. Был клонирован с GitHub скрипт для запуска такой атаки, и она была запущена. На рисунке 6 представлен график nload во время атаки.

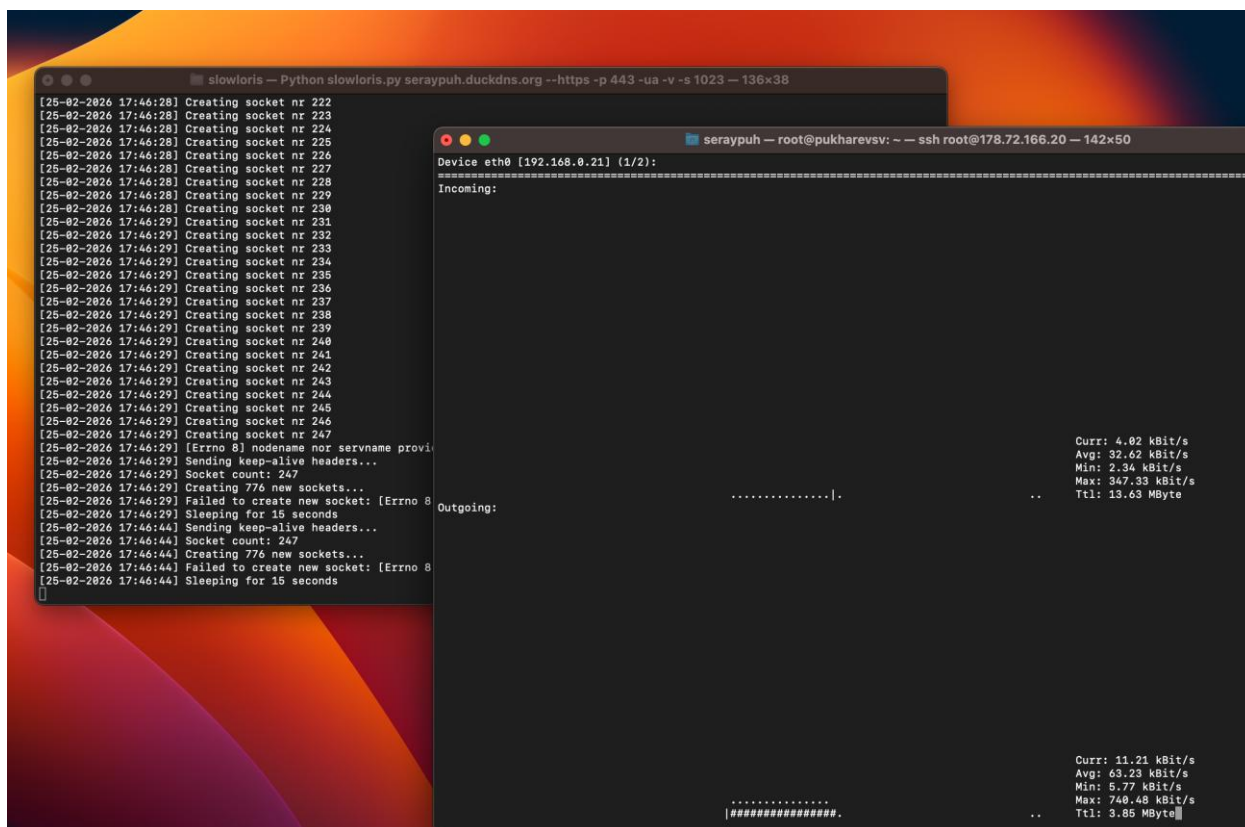


Рисунок 6 – Атака

На рисунке 7 представлено количество ESTAB-соединений при атаке.

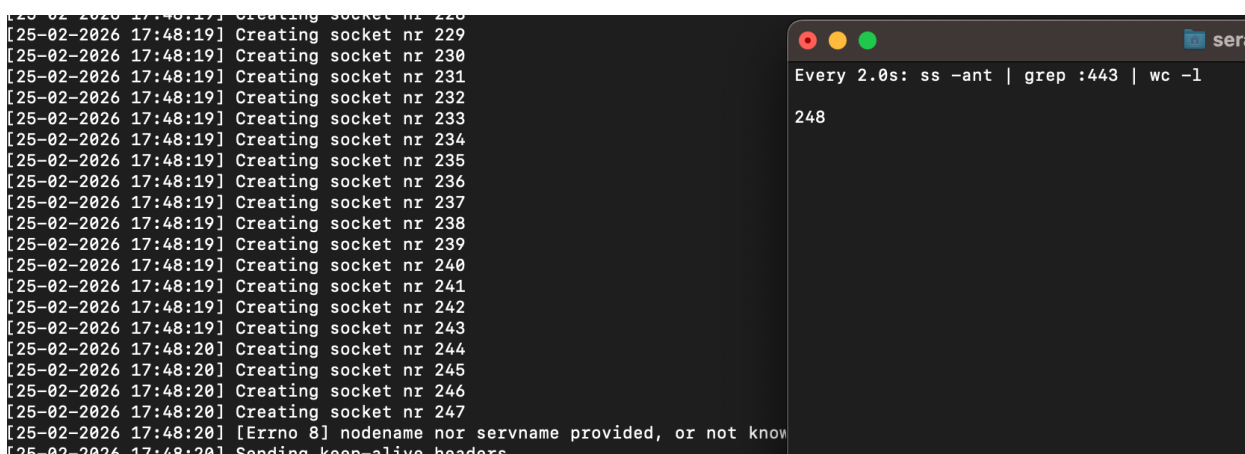


Рисунок 7 – ESTAB-соединения

Подождав некоторое время, атака не принесла результатов, что свидетельствует о правильной настройке конфига nginx.

4 ОТВЕТЫ НА ВОПРОСЫ

1. Балансировка нужна для равномерного распределения трафика между бэкендами, чтобы не перегружать один конкретный.

2. При убийстве всех бэкендов сам nginx не завершает свою работу, но все гейтвэй (8888-8890) падают, из-за чего мы и получаем ошибку 502 Bad Gateway.
3. Мы не пишем 0.0.0.0 потому, что он слушает вообще все подключения, в том числе и извне, в то время, когда 127.0.0.1 слушает только подключения с того же устройства.
4. Slowloris атака не отправляет полный HTTP-запрос, а только его начало, через множество TCP-соединений, и раз в некоторое время поддерживает запрос живым, то есть ничего не требует от процессора, а только нагружает пул множеством соединений, не давая доступа реальным пользователям.
5. Nginx использовался на 7 Прикладном уровне. Если бы он использовался на 4 уровне, то он бы использовал stream, а не HTTP.
6. Атаку slowloris не отразить простым увеличением количеством воркеров, потому что она будет просто открывать новые соединения и не закрывать старые, вследствие чего ошибка сервера появится просто позже.

ЗАКЛЮЧЕНИЕ

В ходе данной лабораторной работы были получены навыки развёртывания nginx, написания конфига для него, а также навыки проведения Slowloris-атаки в ознакомительных целях.